

NAME : S. Kanishka

REG NO : 25082100503912013

SUBJECT : Case Study

CASE NAME : Privacy Policy & Data Protection

CLASS : 2nd B.Com (Honours)

Face Prep , Kamaraj College

Introduction

This policy establishes the organization's commitment to protecting personal data, respecting privacy rights, and complying with applicable data-protection laws. It applies to all employees, contractors, business partners, systems, and processes that collect, use, store, share, or dispose of personal information.

The policy promotes responsible data handling, transparency, accountability, and trust among customers, employees, suppliers, and other stakeholders.

Objectives of the Unit

The Privacy and Data Protection Unit aims to:

- Ensure lawful, fair, and transparent processing of personal data.
- Protect confidential and sensitive information from unauthorized access, loss, misuse, or disclosure.
- Monitor compliance with internal policies and applicable privacy laws.
- Support individuals in exercising their data-protection rights.
- Identify, assess, and reduce privacy-related risks.
- Provide guidance, training, and awareness to employees.
- Investigate and respond appropriately to suspected data breaches.

Elements & Standards of the Code of Conduct

All personnel must follow these standards:

- Collect only the personal data necessary for a defined business purpose.
- Obtain valid consent where consent is required.
- Use personal data only for the purpose communicated to the individual.
- Maintain data accuracy and update records when necessary.
- Restrict access to authorized personnel with a legitimate business need.
- Use secure systems, strong passwords, encryption, and appropriate access controls.
- Retain data only for the approved retention period, then securely delete or anonymize it.
- Do not disclose personal data to third parties without authorization, legal basis, and suitable safeguards.
- Report suspected privacy incidents or security breaches immediately.
- Respect requests involving access, correction, deletion, objection, or portability of personal data.

Violations may result in disciplinary action, contractual consequences, or legal reporting where appropriate.

Ethics & Governance Frameworks

The organization's privacy approach is guided by the principles of:

- **Lawfulness and fairness:** Data is handled legally and without misleading individuals.
- **Transparency:** Individuals are informed about how and why their data is used.
- **Purpose limitation:** Information is used only for specified, legitimate purposes.
- **Data minimization:** Only necessary data is collected and retained.
- **Accuracy:** Personal information is kept correct and current.
- **Security and confidentiality:** Appropriate technical and organizational safeguards are maintained.
- **Accountability:** Management and business units are responsible for demonstrating compliance.

Governance responsibilities should include a designated Privacy Officer or Data Protection Officer, senior management oversight, periodic risk assessments, employee training, vendor due diligence, and audit procedures.

Policy Interpretation & Governance Analysis

This policy should be interpreted in a manner that gives priority to privacy, individual rights, and lawful processing. Where local laws impose stricter requirements, those laws take precedence.

Management should review whether:

- Data-processing activities have a valid legal basis.
- Privacy notices are clear and accessible.

- Security controls match the sensitivity of the data.
- Third-party providers meet contractual and security obligations.
- Data-retention schedules are followed.
- Employees understand their responsibilities.
- Incident-response procedures are tested and effective.

Any uncertainty regarding interpretation should be referred to the Privacy and Data Protection Unit or legal counsel before action is taken.

Preparing a Policy Review Report

A policy review report should include:

1. **Purpose and scope:** State the policy reviewed, review period, and business areas covered.
2. **Compliance assessment:** Identify applicable legal, regulatory, and internal requirements.
3. **Current practices:** Describe how data is collected, processed, stored, shared, and deleted.
4. **Findings:** Record strengths, gaps, risks, non-compliance issues, and control weaknesses.
5. **Incident review:** Summarize any privacy complaints, breaches, or near-miss events.
6. **Risk rating:** Categorize findings by severity, likelihood, and business impact.
7. **Recommendations:** Propose corrective actions, responsible owners, and target dates.
8. **Management response:** Document leadership acceptance, remediation plans, and resources required.

9. Follow-up process: Specify how progress will be monitored and reported.

Conclusion

A strong privacy and data-protection policy helps the organization protect individuals, meet legal obligations, reduce operational risk, and preserve stakeholder trust. Regular review, clear accountability, staff awareness, and timely corrective action are essential to maintaining an effective privacy governance framework.